

Relatório de Secure Code Review

Aplicação: Centralizador Lanches OP
Escopo: Análise Estática de Código e Arquitetura
Data da Análise: 18 de Julho de 2026

1. Visão Geral da Análise

Este documento apresenta as falhas de segurança e melhorias de arquitetura identificadas durante a revisão manual e estática do código-fonte da aplicação Lanches OP. A análise foi efetuada estritamente com base na modelagem de ameaças e mapeamento de vetores de ataques baseados no OWASP Top 10.

2. Vulnerabilidades Críticas e Altas

ID: SEC-01	Vulnerabilidade: Broken Object-Level Authorization (IDOR) no Controle de Pedidos	
Local: routes_admin.py (rotas /order//update_status, /order//details, /order//delete)	Severidade: ALTA	
Explicação Técnica:	O sistema busca os registros de ordens de vendas baseando-se unicamente nos IDs numéricos incrementais transmitidos via rotas (ex: Order.query.get_or_404(order_id)) sem verificar se a ordem pertence ao escopo do subsite que está sob gerência do usuário logado (current_user.subsite_id).	
Impacto:	Permite que qualquer administrador logado leia dados confidenciais de clientes, modifique o status de pedidos ou exclua relatórios pertencentes a outros subsites e franquias da rede.	
Recomendação de Correção:	Adicionar uma validação de propriedade horizontal comparando o subsite_id da ordem consultada com o subsite_id do administrador autenticado.	
Exemplo Seguro:	<pre>order = Order.query.get_or_404(order_id) if order.subsite_id != current_user.subsite_id: abort(403) # Acesso Proibido</pre>	
ID: SEC-02	Vulnerabilidade: Bypass de Autenticação no Webhook do Gateway de Pagamento	

Local: routes_webhook.py (rota /webhook/efi)	Severidade: CRÍTICA
Explicação Técnica:	O endpoint processa a confirmação de transações PIX vindas da EFÍ através do recebimento simples do txid. A rota executa ações financeiras irreversíveis sem realizar validações de autenticidade da chamada, verificação de assinaturas ou filtragem de IPs de origem (whitelist).
Impacto:	Qualquer usuário ou atacante pode simular uma resposta de pagamento concluído enviando um POST arbitrário com o txid de sua ordem de compra, bypassando o faturamento real do centralizador.
Recomendação de Correção:	Implementar validação de assinatura de webhook (X-Efi-Signature) ou restringir o acesso à rota por meio de whitelist de endereços IP de servidores autorizados da EFÍ.
Exemplo Seguro:	<pre>client_ip = request.headers.get('X-Forwarded-For', request.remote_addr) if client_ip not in EFI_WEBHOOK_IPS: return {'status': 'forbidden'}, 403</pre>

ID: SEC-03	Vulnerabilidade: Falta de Proteção Global contra Cross-Site Request Forgery (CSRF)
Local: Globalmente (rotas POST/DELETE em routes_admin.py e routes_user.py)	Severidade: ALTA
Explicação Técnica:	A aplicação não utiliza tokens anti-CSRF para requisições de modificação de estado que trafegam através de cookies de sessão. Nenhum validador de sessão secundário valida a origem do cabeçalho da requisição.
Impacto:	Se um usuário logado visitar um site externo malicioso, este pode submeter requisições ocultas para rotas como /admin/orders/delete-all, executando a ação no servidor usando os cookies válidos do navegador.
Recomendação de Correção:	Ativar a proteção global com Flask-WTF CSRFProtect e embutir o token nos formulários HTML via Jinja2.
Exemplo Seguro:	<pre>from flask_wtf.csrf import CSRFProtect csrf = CSRFProtect(app) # No formulário HTML:</pre>

3. Componentes Analisados e Seguros

Sanitização de Uploads (Anexos): O componente de upload de imagens em *routes_user.py* comporta-se de maneira segura. O fluxo valida extensões em whitelist, limita o arquivo a 2MB e lê a integridade da matriz da imagem via Pillow (`Pillow.verify()`). O arquivo é salvo com hash gerado de forma pseudo-aleatória (UUID4), impossibilitando injeção direta de caminhos transversais no filesystem (Path Traversal) ou injeções via metadados.

Parametrização do Banco de Dados: A camada de banco de dados por meio de SQLAlchemy ORM atua parametrizando todas as strings recebidas pelo usuário final em suas consultas a tabelas (Bound Parameters), impossibilitando ataques de SQL Injection nos mapeamentos padrão da aplicação.